CARLOS GABRIEL GOMES LUZ

APPLICATION SECURITY (APPSEC) | DEVSECOPS | SOFTWARE ENGINEERING

Sao Paulo, SP | +55 (11) 96762-2665 | carlosgabriel.contato2007@gmail.com
linkedin.com/in/dev-carlosgabriel | github.com/CarlossgLuz | carlosg.com.br

PROFESSIONAL SUMMARY

Junior Systems Development Analyst with practical AppSec, ASPM, and DevSecOps experience, pursuing a career in application security. I contribute to XGuardian and develop independent API security and AI agent governance projects, combining Python, automation, tests, execution policies, and traceability.

PROFESSIONAL EXPERIENCE

Xmart Solutions | Santo Andre, SP, Brazil

Junior Systems Development Analyst | Jun/2026 - Present

- Contributing to XGuardian (AppSec/ASPM SaaS), improving features and SAST, SCA, DAST, Container Security, and SBOM reporting.
- Developing dashboards, filters, metrics, and per-application/team scan quota controls for vulnerability workflows.
- Analyzing vulnerabilities and dependencies with OWASP, NVD, CVE/CWE, CVSS, GitHub Advisory Database, and EOL information.
- Participating in RBAC implementation: roles, permissions, segregation of access, and API-operation protection.
- Supporting Sonatype through tests, troubleshooting and documentation; joining vendor meetings in English; evaluating Xygeni.
- Integrating tools through APIs/MCP for QA, documentation and AI-assisted workflows, with emphasis on governance and evidence.

Systems Development Intern | Dec/2025 - Jun/2026

Technical support, web development, Linux, Proxmox, networks, infrastructure, and Zabbix/Grafana observability; promoted to Junior Analyst.

EDUCATION

UNICID | Technology Degree in Systems Analysis and Development | Jun/2026 - In progress

SENAI | Technical Diploma in Systems Development | Jul/2024 - Jun/2026

PROZ | Technical Diploma in Internet Computing | Jan/2023 - Dec/2024

SELECTED PROJECTS & INITIATIVES

APIsec | independent API security lab

Public FastAPI lab reproducing isolated BOLA, BFLA and BOPLA scenarios (OWASP API Security Top 10:2023). Compares vulnerable and protected behavior with synthetic data, Pytest, Ruff, Bandit, GitHub Actions and Docker; exports JSON/Markdown evidence. No external scanning. github.com/CarlossgLuz/APIsec-LabTest

Open-Vaultin | AI Agent Harness Governance | open source

Continuously evolving independent open-source Python project (Early V1). Local-first AI agent governance and durable-context layer: agent/skill catalogs, policies, Codex hooks, task routing through the JEV/TypeSafe decision model and deterministic fallback, execution ledger, evidence, and Git/MCP synchronization. The host retains the agent loop. github.com/CarlossgLuz/Open-Vaultin

Automated release QA | internal initiative

Supporting pre- and post-release checks of platform features, permissions, integrations, and pipelines through APIs, with controlled runs and traceable evidence.

SAST benchmarking

Building controlled OWASP Benchmark-inspired scenarios to compare coverage, accuracy, false positives, and false negatives of static analysis tools.

TECHNICAL SKILLS

AppSec / DevSecOps: ASPM, SAST, SCA, DAST, Container Security, Secrets Scanning, SBOM, Secure SDLC, vulnerability management, Supply Chain Security, RBAC.

Security analysis: OWASP Top 10, OWASP API Security Top 10, NVD, CVE/CWE, CVSS, GitHub Advisory Database, BOLA/BFLA/BOPLA.

Tools: Sonatype Nexus Repository/Lifecycle/Firewall, XGuardian, Xygeni, Semgrep, OWASP ZAP, Gitleaks, Dependabot, Ruff, Bandit, Pytest.

AI / automation: AI Agent Harness Governance, JEV/TypeSafe, agents, skills, MCP, routing, fallback, context control, CI/CD.

Engineering: Python, FastAPI, JS/TS, React/Next.js, SQL, Git, GitHub Actions, GitLab CI/CD, Linux, Docker, AWS, Azure, Proxmox, Zabbix and Grafana.

CERTIFICATIONS & LANGUAGES

Microsoft Azure Fundamentals (AZ-900) | Feb/2026

Scrum Foundation Professional Certification (SFPC) | Oct/2024

English: B2 (Upper-Intermediate) | documentation and international technical meetings; ongoing study.